Historia de Usuario 01

HU-01	**TÍTULO:** Login > Autenticación de usuarios > Acceder al sistema	M7 · Req. 16, 17 · 3 pts

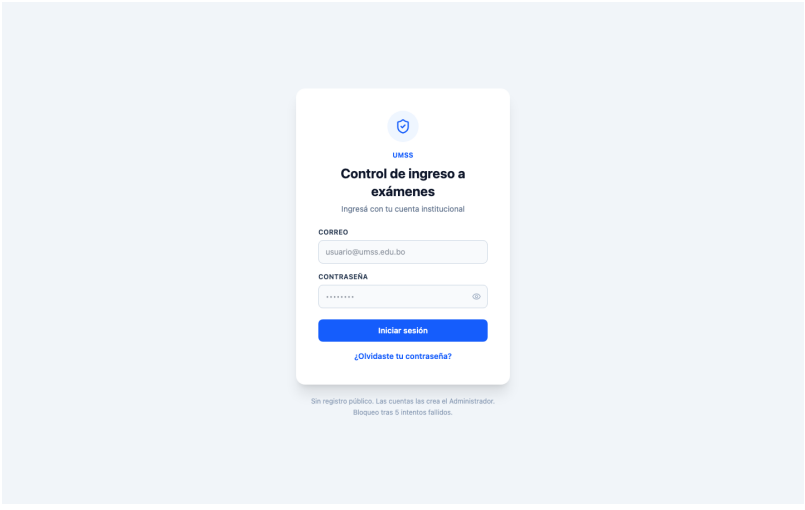
Como usuario registrado del sistema (Administrador, Docente, Personal de control)
Quiero autenticarme con mis credenciales institucionales
Para acceder únicamente a las funciones que corresponden a mi rol

Descripción

Puerta de entrada del sistema y base de las demás historias: sin sesión iniciada no se accede a ninguna pantalla ni a ningún *endpoint*.
No existe registro público. Las cuentas las crea el Administrador y el sistema envía al usuario sus credenciales iniciales por correo institucional; en el primer ingreso se le exige cambiar la contraseña.
Las contraseñas se guardan cifradas y nunca viajan ni se almacenan en texto plano.
El acceso está protegido contra intentos por fuerza bruta: tras cinco intentos fallidos la cuenta se bloquea temporalmente, y el mensaje de error es siempre genérico, para no revelar si el correo existe.
La sesión caduca por inactividad y el cierre de sesión es explícito.
Quien olvida su contraseña pide un restablecimiento desde la propia pantalla de inicio de sesión: el sistema le envía un enlace de un solo uso a su correo, con vigencia limitada. Todo ingreso, salida e intento fallido queda asentado en la bitácora de operaciones (HU-07).

Mockups

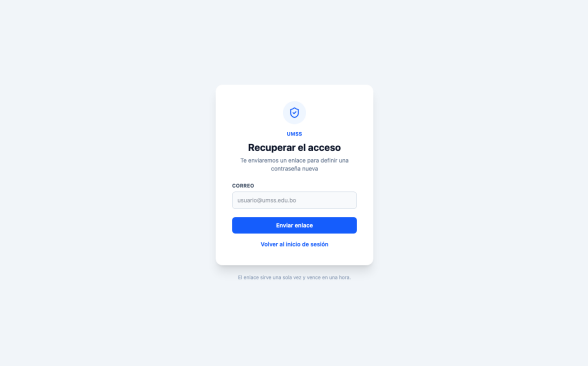
Escritorio

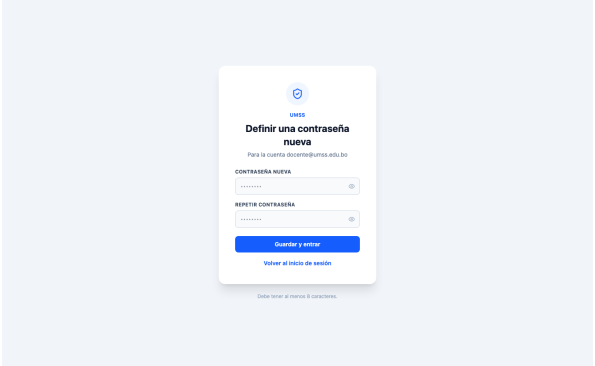


Móvil



Otras pantallas de la historia





Criterios de aceptación

1. Dado que el usuario no ha iniciado sesión y se encuentra en la pantalla de Login, Cuando ingresa credenciales válidas y hace clic en “Iniciar sesión”, Entonces el sistema lo autentica y lo redirige al panel que corresponde a su rol.
2. Dado que el usuario ingresa un correo o una contraseña incorrectos, Cuando intenta iniciar sesión, Entonces el sistema muestra un mensaje genérico de credenciales inválidas, sin revelar si la cuenta existe.
3. Dado que el usuario deja vacío el correo o la contraseña, Cuando intenta iniciar sesión, Entonces el sistema señala los campos requeridos y no envía el formulario.
4. Dado que la contraseña se escribe en el formulario, Cuando el usuario la teclea, Entonces el sistema la muestra enmascarada, con la opción de revelarla.
5. Dado que un usuario no autenticado solicita una dirección protegida, Cuando envía la petición, Entonces el sistema lo redirige a la pantalla de Login y, si era una llamada a la API, responde con un código 401.
6. Dado que el usuario ya autenticado decide salir, Cuando hace clic en “Cerrar sesión”, Entonces el sistema destruye la sesión y lo devuelve al Login.
7. Dado que un usuario falla cinco veces seguidas al iniciar sesión, Cuando supera ese límite, Entonces el sistema bloquea temporalmente la cuenta y rechaza incluso la contraseña correcta hasta que venza el bloqueo.
8. Dado que la sesión del usuario caduca por inactividad, Cuando intenta realizar una acción, Entonces el sistema le exige autenticarse nuevamente.
9. Dado que la cuenta de un usuario está inactiva, Cuando intenta iniciar sesión con credenciales correctas, Entonces el sistema le niega el acceso.
10. Dado que el Administrador crea una cuenta, Cuando la guarda, Entonces el sistema envía al usuario sus credenciales iniciales a su correo institucional.
11. Dado que el usuario ingresa por primera vez con las credenciales que recibió, Cuando entra al sistema, Entonces se le exige definir una contraseña nueva antes de continuar.
12. Dado que el usuario olvidó su contraseña, Cuando usa “¿Olvidaste tu contraseña?” e indica su correo, Entonces el sistema le envía un enlace de restablecimiento de un solo uso y con vigencia limitada, y responde siempre igual exista o no ese correo.
13. Dado que el usuario abre un enlace de restablecimiento vencido o ya utilizado, Cuando intenta

cambiar su contraseña, Entonces el sistema lo rechaza y le ofrece solicitar uno nuevo.

14. Dado que se produce un inicio de sesión, un cierre de sesión o un intento fallido, Cuando ocurre, Entonces el sistema lo registra en la bitácora de operaciones.
15. Dado que el usuario accede desde un dispositivo móvil, Cuando abre la pantalla de Login, Entonces la interfaz se adapta de forma completamente responsiva.

Pruebas automatizadas

- `AuthenticationControllerTest`: ingreso correcto, mensaje genérico ante credenciales incorrectas y validación de campos vacíos (criterios 1 a 3).
- `LoginSecurityTest` y `AuthenticationHardeningTest`: bloqueo tras cinco intentos, rechazo de la contraseña correcta durante el bloqueo, cuenta inactiva y metadatos del intento (criterios 7 y 9).
- `SessionInactivityTest`: caducidad de la sesión por inactividad (criterio 8).
- `BitacoraSesionTest`: inicio, cierre e intento fallido asentados en la bitácora, y que la contraseña enviada nunca queda registrada (criterio 14).
- `CambioContrasenaTest`: cambio con la contraseña actual, rechazo si no coincide, confirmación obligatoria y bloqueo del resto de la API mientras siga la contraseña inicial (criterio 11).
- `RestablecimientoContrasenaTest`: envío del enlace, respuesta idéntica para una cuenta inexistente, enlace de un solo uso, vencimiento, token falso y liberación del bloqueo (criterios 12 y 13).
- `CredencialesInicialesTest`: envío de credenciales al crear la cuenta, sin devolver nunca la contraseña generada (criterio 10).
- Pruebas de las pantallas (`Login`, `OlvideContrasena`, `RestablecerContrasena` y `CambiarContrasena`): formularios, mensajes de error y enmascarado de la contraseña (criterios 2 a 4).
- `Aplicacion.test.jsx`: redirección al Login sin sesión, cambio obligatorio de contraseña y apertura del enlace del correo (criterios 5 y 11).